

SEE ALSO Newsletter of April 10, 2024

[doc. web n. 10002287]

Provision of March 21, 2024

Register of provisions

n. 196 of March 21, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by

Prof. Pasquale Stazione, president, Prof.

Ginevra Cerrina Feroni, vice president, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European

Parliament and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to the

processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing

"Code regarding the protection of personal data,

containing provisions for the adaptation

of the national legal system to Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter

"Code");

HAVING REGARD TO Regulation No. 1/2019 concerning

internal procedures with external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

Resolution of the Guarantor No. 98 of 4/4/2019,

published in G.U. No. 106 of 8/5/2019 and in

www.gpdp.it, doc. web n. 9107633 (hereinafter

"Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary

General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the

organization and functioning of the office of the Guarantor for the

protection of personal data, at www.gpdp.it, doc.

web n. 1098801;

REPORTING Prof. Ginevra Cerrina Feroni;

WHEREAS

1. The investigative activity

On XX, the Lazio Region (hereinafter "Region") transmitted to the Authority, pursuant to Article 33 of the

Regulation, a notification of a personal data breach, concerning a cyber attack,

caused by ransomware-type malware, on the information systems managed by LAZIOcrea S.p.a.

(hereinafter "Company" or "LAZIOcrea") as the

data processor on behalf of the Region and several entities of the regional health service

(notification subsequently supplemented on XX and XX).

In consideration of the high number of affected individuals

involved and the nature of the personal data subject to the breach, the Office requested information from the aforementioned Company regarding the cited personal data breach, as well as the security measures adopted, with particular reference to the technical and organizational measures taken to ensure the availability and resilience of the processing systems and services and the timely restoration of the availability and access to personal data in the event of an incident (notes of XX and XX, to which LAZIOcrea responded with notes of XX and XX, XX and XX).

Subsequently, an inspection activity was carried out against the aforementioned Company in the months of XX and XX.

With the notification of XX, the Region declared that it had “suffered a cyber attack that compromised the functionality of the services offered by the regional CED; a technical verification of what happened is currently underway, and at this time it is not possible to determine whether there has been data loss, the categories and approximate number of records of the personal data in question, and the possible consequences of the personal data breach.”

In a note dated XX, LAZIOcrea, in response to the aforementioned request for information made by the Office, stated that:

“following the cyber attack that occurred on the night of July 31 (caused by ransomware-type malware), some

information systems of the Lazio Region were deactivated, temporarily rendering the related services, data, and information processed unavailable”;

it was “committed to providing support for the ongoing investigation being conducted by law enforcement and other competent authorities for national security”;

“analysis activities were underway to ascertain the scope and extent of the personal data breach [...] once the dynamics of the events were fully understood, including the historical and technical aspects”;

it was “necessary to operate in parallel to restore services while implementing all safeguards and precautions to prevent the systems from suffering another attack.”

Subsequently, in a note dated XX, LAZIOcrea represented that:

“the attack began in the late evening of July 31 but became evident in the early hours of the morning of August 1 when some virtual machines became unusable. This was a cyber attack aimed at propagating malware belonging to the family known as

‘RansomEXX’, also known as ‘Defray777’, which was promptly reported by our cybersecurity service to the CSIRT and CNAIPIC with a notification/report via email on August 1 to

****10.22.**** The attack targeted the application layer of the data center virtualization, forcing the Company to take all systems offline to ensure that the integrity and confidentiality of the data were not compromised;

“the essential services related to the emergency activities of 112, 118, transfusion centers, Emergency Room, and Civil Protection were never interrupted or compromised even during the investigative activities aimed at determining the extent of the incident. This was partly because they were segregated from other applications”;

“all other services and applications residing on the data center have been restored or will be restored [...] after verifying the removal of any residual and/or possible contamination and reconfiguring the systems according to the pre-existing security architecture. For informational purposes, vaccination activities against Covid continued, and the booking service for the aforementioned vaccines was restored within four days before new administration slots became available. Slots that at the time of the incident were already occupied until the subsequent August 13. Starting from August 16, third-party application providers residing in the data center will have the opportunity to reinstall their systems to resume the provision of related services”;

“the origin of the incident seems, at this stage, to be traced back to the injection, on one or more client

computers operating remotely via VPN, of malicious software that created a communication channel (backdoor) between the infected client computers and the group of cybercriminals. The cybercriminals, exploiting the same credentials, subsequently managed to access the corporate network and from there to move 'laterally' within the so-called subnets, performing an escalation on administrative accounts that were probably identified by intercepting low-level data packets occurring on that network at the time of user logins. These criminals seem to have utilized the skills of another group of hackers to whom the encrypted passwords were passed. This further group of criminals, exploiting a presumed vulnerability of the operating system, managed to decrypt a password that was then matched to one of the four user IDs with administrative privileges previously identified by the hackers”;

“experts then conducted checks to assess whether the attack, which did not compromise the integrity and confidentiality of the data, allowed intruders to appropriate the same through exfiltration and/or transfer techniques. The analyses confirmed that as of today, exfiltration can be ruled out since no data flows to the outside were detected during the attack period”;

“the files found in the temporary directories are indeed derived from the automation of the tools used for the attack and aimed primarily at verifying the system architecture and the inventory of the applications present to better prepare the attack according to the detected system configurations. Moreover, the firewall policies active during the attack did not allow the use of FTP, SSH, and SFTP protocols from within the data center perimeter to the Internet. In any case, activities of ‘Cyber Threat Intelligence’ are still ongoing by the consultants engaged to ensure that information belonging to Laziocrea is not made public, even if related to data already known before the attack. At the moment, despite the expiration of the ultimatum, no new information has been made available on the web, particularly on the so-called illegal ‘dark web’”;

“the data and information present in the databases have therefore been unavailable for the time necessary to restore the applications and secure the perimeter of the data center through its reconfiguration. For some systems, the information will remain unavailable until reactivation, which will occur completely over the next few days. Therefore, there are no serious limitations to the freedoms and fundamental rights of those concerned.”

Finally, with the notification of XX, LAZIOcrea provided the list of applications and services involved in the breach – indicating those restored immediately and those in the process of restoration – and the list of those that remained active as they were segregated from the infrastructure subject to the attack, stating that:

“based on the investigations conducted by the internal Cyber Security structure, by CSIRT, by CNAIPIC, and by Leonardo S.p.A., it appears that the attack, which began at 15:05 on the afternoon of July 31, 2021, originated from the compromise of an account belonging to a regional employee whose access credentials were stolen through malicious artifacts (back door) installed on the personal computer used by the employee for remote connections to the corporate network necessary for smart working”;

“forensic analysis activities have established that the artifacts were injected on March 25, 2021, and that they were not detectable on the host computer by antivirus and malware software. During the forensic analysis of the copy of the computer in question, the scan yielded a negative result despite the so-called ‘signature database’ of the antivirus/malware software having been updated by forensic investigators to the most recent date of August 10. The user’s remote connections to the corporate network were still protected by a VPN”;

“there were also attempts of anomalous access in the confronting six user accounts on the OWA interface of the mail systems from April 12, 2021, until July 26, 2021. However, these attempts do not seem to be connected to the incident and mostly resulted, with the exception of one user account, in denial of access to the mail service”;

“in conclusion, the attack was launched in the afternoon of Saturday, July 31, 2021, using the first compromised account and became noticeably apparent when the first malfunctions of some virtual machines in the Data Center began to occur in the early hours of the morning on August 1”;

“the attack targeted the machines located in Room ‘B’ [of the data center managed by the Company], where various types of hardware were present for both computational purposes and in terms of

storage and networking devices (essentially Cisco, Dell, Fortigate, etc.). Being modular machines and scalable in terms of equipment and computational and storage characteristics, they are managed by proprietary firmware on which the Microsoft Active Directory Hosts and VMWare & Microsoft Hyper-V virtualization environments were installed. On this virtualization environment, virtual machines with Windows Server and Linux operating systems were configured and installed to serve the services and applications necessary for the processing carried out by LAZIOcrea both as Data Controller and as Processor for other Data Controllers, and in particular for the Lazio Region.”

During the aforementioned inspection activities, LAZIOcrea also declared, as indicated in the minutes of the operations carried out, that: “as a result of the forensic analyses conducted, it appears that, in March 2021, a malicious actor introduced a backdoor – unknown and undetected, neither at the time nor during the analyses, by more common antivirus and antispyware software – into the company laptop used by [...] an employee of the Lazio Region, which was likely used to acquire the authentication credentials” attributed to the employee;

“on July 31, 2021, the aforementioned authentication credentials were used to remotely access the Company’s network and to conduct the preliminary actions for the cyber attack. In particular, the malicious actors carried out a series of scanning activities aimed at acquiring information about the network and the server systems present therein. As part of these activities, they identified the server with hostname ‘RLWSIRIFT01’ on which base software was installed for which no updates or security patches from the manufacturer were available. This circumstance was due to the need to ensure the operation of a legacy web application that required a specific version of the operating system and application server. Exploiting known vulnerabilities of the base software present on the aforementioned server, the malicious actors managed to obtain authentication credentials with administrative privileges [...] used in the subsequent phases of the cyber attack”;

“the Company became aware of the cyber attack through a report from a healthcare operator who, unable to access certain services provided by the Company, contacted the on-call system administrator for the healthcare area around 05:00 on August 1, 2021. Following the report and the initial analyses conducted, the system administrator confirmed the significance of the security incident and proceeded to contact other system administrators, some of whom immediately went to the data center. At approximately 06:15 on XX, the report was brought to the attention of the director of the Company’s Infrastructure Systems Department”;

“with reference to the initiatives taken following the detection of ‘hostile activities’ (2,189 alerts) by the ‘Microsoft Windows Defender ATP console’ on the evening of July 31, 2021, [...] during the activation of the SOC service of Leonardo S.p.a., this monitoring tool was not staffed 24/7” and, therefore, “it was not possible to manage these alerts with ‘greater’ timeliness.” During the investigation, LAZIOcrea also provided the list of data controllers, including the Lazio Region, on behalf of whom it processed the personal data involved in the breach.

1.1 Measures in place at the time of the breach

With reference to the measures in place at the time of the breach, the Region, with the supplementary notification of XX, stated that “while the Data Center and the procedures of LazioCrea S.p.A. for data security and protection are ISO 27001 certified, it is represented that with executive determination no. XX of XX, the Lazio Region regulated the assignment and use of ICT equipment for personnel in service [...]. Furthermore, within the Regulation of the organization of the offices and services of the Regional Council no. 1/2002 and subsequent amendments, the organizational model regarding the protection of personal data is regulated in accordance with Articles 473, 474 and subsequent ones. Finally, within the regional intranet, frequently asked questions (FAQ) regarding the use of IT devices during extraordinary smart working are available.”

Regarding the technical and organizational measures adopted to ensure the availability and resilience of the processing systems and services, as well as the timely restoration of the availability and access to personal data in the event of an incident, the Company provided copies of the backup procedures, the business continuity and disaster recovery plan, and the incident management process and

****Data Breach Management Procedure****

in effect as of July 31, 2021.

During the inspection activities, LAZIOcrea stated that:

“it uses Microsoft’s Active Directory as its IT authentication system. This system is used for the authentication of users from the Company, the Lazio Region, and other external entities for access to systems certified to the domain (workstations and servers) and to certain web applications, as well as for remote access via VPN to the Company’s network,” specifying that “at the time the personal data breach occurred, a multi-factor authentication procedure for VPN access was not in place”;

“it has defined different password policies for the various types of accounts used by the personnel of the Company, the Lazio Region, and other entities. In particular, at the time the personal data breach occurred, the passwords for accounts without administrative privileges were required to consist of a minimum of 8 characters, contain characters from at least three categories (uppercase letters, lowercase letters, numbers, special characters), not coincide with the last four passwords, and be changed at most every 90 days; the passwords for accounts with administrative privileges, on the other hand, were required to consist of a minimum of 20 characters, contain characters from at least three categories (uppercase letters, lowercase letters, numbers, special characters), not coincide with the last four passwords, and be changed at most every 30 days”;

“it has implemented measures to segregate the systems present within the data center. In particular, the servers hosting the various databases are connected to segregated networks compared to other networks, which is why the cyber attack at the end of July did not involve the data stored within such servers. Similar segregation measures are applied to servers that provide particularly critical services [...] or dedicated to specific clients [...]”;

“with regard to the security measures related to network segregation, in place at the time of the personal data breach, ‘there are two levels of firewalling: the first is dedicated to filtering communications between the networks on which the workstations of the employees of the Lazio Region and the Company are located (connected to LAN networks accessible at the offices of the regional offices and the Company) and those on which the server systems are located; the second is instead used for filtering network traffic to and from the data center and communications between the networks on which the server systems are located. In particular, the firewalling rules are configured based on the indications provided by the various project managers. In some cases, network traffic filtering is also implemented between the different architectural layers of a system (front-end, back-end, database) or for the different environments (development, testing, and production). Some critical systems or services [...] are instead connected to dedicated and physically separate networks from the other systems present in the data center”;

“at the end of July 2021, when the security incident subject to the inspection occurred, the filtering rules did not prevent, at the network level, the reachability of the compromised server systems from the network used for the VPN access of the employees of the Lazio Region, among which [...] the account of the employee]. For this reason, malicious actors were able to conduct reconnaissance of the server systems visible from the network used for VPN access, as well as to identify one with an outdated operating system (‘RLWSIRIFT01’) affected by some known vulnerabilities. [...] one of these vulnerabilities was then exploited to acquire the credentials for administrative privileges [...] used in the subsequent phases of the cyber attack”;

“until June 30, 2021, it relied on a Security Information and Event Management (SIEM) service, based on IBM technology and provided by Fastweb S.p.a. under a Consip agreement. From July 1, 2021, the Company activated a new SIEM service, based on Microsoft technology (Sentinel). At the time the cyber attack occurred, the Company did not have personnel (internal or external) dedicated to the 24/7 analysis of alerts generated by Microsoft’s SIEM, awaiting the activation of a security operations center (SOC) service provided by Leonardo S.p.a., which took place in the first days of August 2021”;

“at the time of the security incident, it was using Dell’s Data Domain product as its backup management system. Specific backup management procedures had not been defined, but it was expected that each project manager would communicate, at the time of release into operation, through a specific form, among other things, information on the type and retention of backups to be performed. The frequency of backups was daily (starting around 8:00 PM)”;

it has conducted audit activities on the incident management process and provided copies of the plans and audit reports;

“on an annual basis, it conducts internal audit activities on each of the processes provided by the ISMS [...] The Company has planned, within the audit program for the year 2022, the execution of a specific audit activity on the security incident that occurred at the end of July 2021, also in order to close the observation made by the certification body (Apave Certification Italia S.r.l.) during the surveillance visit for the maintenance of ISO 27001 certification that took place on XX and XX.”

1.2 Measures Taken Following the Violation

With reference to the measures taken following the violation, the Region, with the aforementioned notification dated XX, intended to refer “to the documentation attached by LazioCrea to the final notification of XX.” The Company, with the referenced notification dated XX, represented that:

“at the time of the incident, along with taking the systems offline, corrective actions were implemented including: i) the establishment of a crisis team; ii) the recruitment of external consultants experienced in specialized activities of incident response, cyber security, and system remediation; iii) the reactivation of each application system, subject to compatibility with investigative activities and verification of the security of the applications themselves, also resorting to bridge installations on Cloud environments provided by certified Agid CSP providers; iv) the activation of all necessary activities and controls to ensure the physical and logical security perimeter of the data center; v) the identification of a series of remedial actions to enhance the security of the systems and the consequent protection of personal data, despite the pre-attack security levels already meeting industry standards, as the Company had obtained ISO 27001 certification”;

“in all cases, a communication was made both on the institutional website of the Lazio Region and on that of Laziocrea to inform all users and interested parties of the actual extent of the service disruption and the risks related to personal data”;

“all applications owned by Laziocrea and managed by Laziocrea as the Responsible Party of the Lazio Region or other Controllers have been restored [...]. The processing managed on behalf of the Region as Responsible Party [...] (REG 09 – RES065 within the processing DSINF 45 -Development, Maintenance, Administration, User Support of the Management System for Notices and Calls of the Lazio Region for Culture) has been restored from backup, and for the Calls for Film Production and Film Promotion, while containing all the submitted applications, it encountered some issues with the restoration of the documentation attached to the aforementioned applications. The problem concerns the funded practices for the years 2017-2018-2019 and 2020, which are about 1,800; for some of these, it was not possible to restore all attachments of the applications now archived from the backups [...]. There is, however, the possibility that some of the documents may not be restorable because the restored file is corrupted”;

“at the moment, there is no evidence of exfiltration of structured data, although it cannot be absolutely ruled out that files containing information may have been viewed or consulted during the attack. During the period in which the ransomware propagation occurred, no connections to the outside were observed that would suggest a possible uncontrolled transfer of information.”

To carry out the data and system restoration operations, LAZIOcrea, in the absence of tools for decrypting “files encrypted by the ransomware,” recovered “large portions of files using data carving tools.” During the inspection activities, the aforementioned Company stated that:

“following the incident, a procedure with two-factor authentication was activated, based on the use of username/password and a one-time password (OTP)”;

“following the violation of personal data, the password policies for accounts without administrative privileges were modified, increasing the minimum length to 10 characters”;

“based on the indications provided by the Region in terms of priority in restoring services and in accordance with the investigative needs expressed by the judicial authority, the Company proceeded to reinstall all domain servers, including the domain controllers, using the intact copies of the various applications. In the context of this restoration activity, the Company also availed itself of the consultancy of Microsoft, which certified the absence of so-called ‘dummy accounts’ on the Active Directory that could have been created by malicious actors during the cyber attack”;

“a new backup management system based on Commvault technology has been adopted, which is

located on-premises at the Company's data center, but which allows, where necessary, the use of the cloud service offered by the provider. The new system allows for easier management and monitoring of data and system backups. It is still expected that each project manager will communicate, at the time of release into operation, through a specific model, among other things, information on the type and retention of backups to be performed";

"following the security incident, some services and systems have been restored, and are still provided, in a cloud environment, in particular: on Amazon's AWS cloud (data center located in Lombardy) the healthcare service booking system (including vaccines and SARS-CoV-2 tests) and the regional vaccination registry; on Microsoft's Azure cloud (data center located in Ireland) the Identity and Access Management (IAM) system and various institutional web portals (e.g., the Lazio Region portal)";

"following the security incident that occurred at the end of July 2021 [...] a series of initiatives aimed at reviewing and strengthening the filtering rules applied to communications between and towards the server systems have been initiated";

"remote access to the systems and services present in the data center occurs via VPN (based on **Pulse Secure Technology**. In this case, a first level of filtering policy is carried out by the VPN concentrators, which apply different privileges and rules based on the domain groups of which the user is a member;

"it has identified the (few) servers that, to ensure the operation of certain legacy services, still use obsolete operating systems and has taken appropriate measures for segregation, at the network level, as well as for monitoring security events."

From the documentation on record, it is evident that, following the cyber attack in question, the Region experienced the temporary unavailability of numerous information systems, through which data on the health of beneficiaries of the regional health service are processed (e.g., systems dedicated to health bookings, Covid-19 vaccination, teleconsultation, storage of reports related to laboratory tests – including those related to Covid-19 swabs – digital prescriptions, as well as the regional vaccination registry system, the Salute Lazio portal). The lack of access to the data stored on the aforementioned systems, which constitutes a violation of personal data, was, on one hand, a direct consequence of the cyber attack (which, by encrypting the content of certain server systems, rendered them unavailable) and, on the other hand, an indirect consequence arising from LAZIOcrea's decision to shut down all server systems due to the inability to determine which were compromised and, given the absence of their segregation, to prevent further propagation of the malware.

1.3 The Procedure Initiated by the Authority

Based on the above, with a note dated XX (prot. n. XX), the Office issued a notification of violation pursuant to Article 166, paragraph 5, of the Code to the Lazio Region as it was found that the processing of personal data in question was carried out:

- in a manner not compliant with the principle of "integrity and confidentiality," in violation of Article 5, paragraph 1, letter f), of the Regulation;
- failing to implement technical and organizational measures to promptly identify a personal data breach, as well as to ensure on a permanent basis the confidentiality, integrity, availability, and resilience of processing systems and services, in violation of Article 32 of the Regulation;
- in a manner not compliant with the principle of "data protection by design" as per Article 25, paragraph 1, of the Regulation.

With a note dated XX, the Region requested an extension of the deadline for submitting defensive briefs, which was granted by the Office due to the declared "complexity of the systems and services managed by LAZIOcrea on behalf of the Lazio Regional Authority and other data controllers" and considering that "with D.M. of December 9, 2022, the date for the regional elections for Lazio was set for February 12 and 13, 2023."

With a note dated XX, the Region submitted its defensive briefs, within which – preliminarily – after specifying that "the incident that occurred on the night between Saturday, July 31, and Sunday, August 1, 2021, received media coverage far exceeding the actual consequences of the cyber attack on the

rights and freedoms of the data subjects,” it illustrated the roles and relationships “of the Regional Council (Data Controller) and LAZIOcrea S.p.A. (Data Processor),” specifying, in this regard, that:

“LAZIOcrea S.p.A. is a joint-stock company, wholly owned by the Lazio Region and established pursuant to Article 5 of L.R. No. 12 of November 24, 2014, according to the in-house providing organizational model,” which provides services and activities “to the structures of the Regional Council,” particularly in areas of intervention such as: “technical-administrative, organizational, and managerial support related to the exercise of regional administrative functions [...]; design, implementation, and management of the regional digital Agenda strategy, including the Regional Information System”;

“the regional administration exercises programming, strategic-operational guidance, and control functions over it. The Lazio Region exercises what is known as ‘similar control’ over LAZIOcrea and defines strategic and operational objectives. [...] The Regional Council also approves its directives regarding guidance and control activities for the purpose of exercising similar control over the in-house company”;

based also on what is defined in the statute, “the management of the Regional Information System and the Data Center is, therefore, entirely entrusted to LAZIOcrea S.p.A.,” for which the latter, “within its competencies, makes the infrastructure and information system available to the entities adhering to the Regional Information System, in order to provide them with the necessary IT services for the integration of their information systems with the aforementioned Regional Information System”;

“by virtue of the fact that LAZIOcrea, acting on behalf of the Regional Council, processes data necessary for the provision of essential services, operates as the Data Processor for the management of the Data Center on behalf of the Data Controller, having been formally designated in this role with DGR 797/2017 and DGR 840/2018,” and such designation “was made having evidence that it provided sufficiently ample guarantees for the implementation of adequate technical and organizational security measures, in terms of specialized knowledge (technical skills regarding security measures and data breaches),

"reliability and available resources."

With the same note, it was highlighted that:

"regarding the identification, handling, and timely reporting of the violation, it is believed that the conduct of the Data Controller was correct and adequate. The analysis of the timing indeed highlights that, in light of the violation that occurred between July 31 and August 1, 2021 (it is worth noting that July 31 was a Saturday), the Data Controller, already on the evening of August 1, informed this Authority about the incident via certified email (PEC), through its then-current DPO, and on date XX, made the preliminary notification of the personal data breach through the online procedure available on the institutional website of the Authority: all of this, therefore, without unjustified delay and within the 72 hours prescribed by Article 33 of the Regulation. Furthermore, it is specified that the Data Controller, in the exercise of its control function, at the time of the incident, was aware that the designated Processor had already adopted the highest security standards in order not to compromise the confidentiality, integrity, and availability of the personal data processed on behalf of the Controller," having "obtained on December 11, 2020 (a date well before the violation in question) the certification of security standards for the protection of information UNI CEI EN ISO/IEC 27001:2017 through the certifying body, APAVE Certification Italia S.R.L.”;

"considering that the Regulation itself encourages the use of certifications to be obtained through appropriate certification bodies (Articles 42 and 43 of the GDPR), it is believed that the Regional Council has operated in accordance with the Regulation both in the phase of verifying the existence of sufficient guarantees on the part of the Processor to implement technical and organizational measures aimed at ensuring processing that provides adequate protection of the rights of the data subject (acquisition of certification), and in the phase of implementing measures and improving the security and data protection system, translating the certifier's observations in the 2021 POA into improvement actions funded with specific budget allocations. In the light of the above, the Controller ensured that

the certified quality standards on the Regional Information System and on the Data Center were maintained even in the post-incident management; in this regard, it is highlighted that, thanks to the adjustment of security systems and the adoption of improvement actions funded in the 2021 POA, LAZIOcrea has retained the ISO 27001 certification even following the maintenance visits that took place on November 26-29, 2021, and November 24-25, 2022, and obtained [further] certifications [...]. It is worth concluding by specifying that, in the perspective of improvement, on the part of the Processor, of the security system and maintaining the capacity to implement adequate technical and organizational measures, as of today, the Data Center managed by LAZIOcrea on behalf of the Lazio Region is also accredited with the National Cybersecurity Agency (ACN). In the absence of an applicable code of conduct, it is believed that the Processor's adherence to the aforementioned certification mechanisms, at the request of the Controller, constitutes full evidence of sufficient guarantees for the implementation of technical and organizational measures in terms of specialized knowledge, technical skills regarding security measures and data breaches, and degree of reliability";

"regarding the specific instructions that the Controller provides to the Processor, in addition to the designation of the company with DGR 797/2017 and DGR 840/2018 [...], the approved and funded projects on cybersecurity contained in the 2021 Annual Operational Plan pursuant to DGR n. 1024/2020 should also be noted in the legal relationship between the Regional Council and LAZIOcrea S.p.A. [...]. With specific reference to DGR n. 840/2018, it is further highlighted that in Annex G, [...] the Controller, in the exercise of its function, has provided specific instructions also regarding the security of personal data processing";

with reference to the failure to adopt adequate measures to promptly detect the personal data breach: LAZIOcrea, "on behalf of the Controller, at the time of the incident that occurred in July 2021 had already [equipped itself] with the Microsoft Windows Defender ATP console and Microsoft's Security Information and Event Management (SIEM), which correctly sent alerts regarding the detection of possible malicious activities. The detection tools mentioned above were already in operation at the time of the breach and were adopted within a broader planning of cybersecurity activities that dates back to a period prior to the incident and that, as provided in Annex B section B1 of the POA for the year 2021 (DGR 1024/2020), would lead to the implementation of the service called "CYBERSECURITY - Implementation of Internal SOC Service"; in the cited DGR, the aforementioned activity was funded and the related commitment was made in the appropriate budget chapter. [...] It is worth emphasizing that the Controller, with the aim of adopting increasingly adequate measures to promptly detect potential personal data breaches, cooperated with LAZIOcrea to accelerate the operationalization of the SOC by anticipating the completion of the preliminary design of the interventions to the early months of 2021, despite the fact that, for public administrations, the current regulations at..."

to be effective, allowing for the restoration of data without significant loss. This demonstrates that the measures in place were adequate to ensure the continuity of operations and the protection of personal data."

"Furthermore, it is important to note that the incident response plan was activated promptly, and the necessary notifications were made to the relevant authorities in accordance with the applicable regulations. The Titolare and the Responsabile acted in good faith and with due diligence in managing the incident, which further supports the assertion that they complied with their obligations under the GDPR."

"Finally, in light of the above considerations, it is concluded that the Titolare and the Responsabile have demonstrated a commitment to maintaining a high standard of data protection and security, and that the measures implemented were appropriate and effective in mitigating the risks associated with the incident."

adequate and functioning, so much so that the applications involved in the incident have been correctly reinstalled and restored. For the specific measures adopted and for the description of the backup systems in place, reference is made in full to the statements of the Responsible Party";

"the fact that the Responsible Party subsequently acquired a new backup system does not at all

highlight the inadequacy of the one already in place, but rather demonstrates the ability to adapt, with continuous improvement interventions, the technical and organizational measures implemented following ongoing assessments of the level of risk associated with processing. The implementation of additional technical and organizational security measures post-incident by LAZIOcrea is indeed part of a broader adjustment project, which, as previously mentioned, was largely planned and entrusted by the Data Controller with timelines preceding the incident, which includes, among other things, systems and procedures for backup, disaster recovery, and business continuity, aimed at improving the level of security in order to protect the processing operations carried out on its systems and to mitigate risks”;

with reference to data protection by design: “the challenge regarding data protection by design by this Authority is not contextualized in the description of specific facts, acts, or omissions attributable to any inadequate conduct of the Data Controller, but rather constitutes a reference to the current regulations in this regard”;

“the Data Controller has acted towards the Responsible Party, through the acquisition of the certifications repeatedly mentioned, evaluations regarding the adequacy of the systems and the countermeasures adopted [...]. The Data Controller, considering that the incident occurred exploiting a type of malware not detectable by the antivirus systems/applications available at the time (as evidence of this, it is noted that it was not detected even by experts during the forensic investigation almost two weeks later with detection systems updated as of August 10, 2021), has adopted technical and organizational measures that are to be considered objectively adequate to promptly identify possible violations when compared to the known framework at the time of the facts, in terms of cybersecurity. Furthermore, the security systems in place at the Responsible Party were suitable to ensure on a permanent basis the confidentiality, integrity, availability, and resilience of the processing systems and services, in fact also respecting the principle of “data protection by design” as per Article 25, paragraph 1, of the Regulation. It is worth noting that the same Article 25, paragraph 3, of the Regulation admits that the certification mechanism may be used as an element to demonstrate compliance with the requirements set out in paragraphs 1 and 2 of the same article”;

“despite some of the systems involved in the incident being pre-existing to the entry into force of the Regulation, the Data Controller and the Responsible Party, each within their own competence, have worked to review and adapt the security measures in place regarding the protection of personal data. Referring to the reasons stated above and emphasizing the limited consequences post-incident, it is considered that the checks and adjustments made even on the systems prior to the GDPR have provided adequate guarantees regarding the rights of the data subjects”;

with specific reference to the duty to assess risks to the security of personal data, considering the impact on the rights and freedoms of the data subjects, and to effectively counter those identified, “the risk assessment system adopted by the Responsible Party is to be considered adequate when compared to the threats known at the time of the incident; in particular, both antivirus systems and alert systems were present. However, it is reiterated that the malware, from which the incident originated, was in fact unidentifiable to the extent that it evaded the best antivirus systems/applications available at the time, including those adopted for the forensic investigation. [...] The Data Controller, moreover, in the exercise of its control function, at the time of the occurrence was aware that the designated Data Processor had adopted the highest security standards in order not to compromise the confidentiality, integrity, and availability of the personal data processed on its behalf,” reiterating once again the element of achieving the aforementioned certifications by the Company;

with specific reference to the duty to take into account security requirements as soon as possible in the design and development of the system, integrating and continuously conducting relevant tests, “the Regional Council promptly took into account the observations contained in the certification obtained by the Data Processor on December 11, 2020, and translated them into concrete improvement actions in the Annual Operational Program 2021 (POA 2021), approved by D.G.R 1024 of December 22, 2020”;

with specific reference to the duty to define the processing of data in such a way that a minimum number of people need to access personal data to perform their functions, and to limit access

accordingly, "the authentication for remote access, via 'VPN Pulse Secure' single factor, was indeed adequate to the general framework known at the time of the facts regarding possible vulnerabilities of the systems and possible attack vectors. No observations are reported by the certifying body for the ISO standard.

****27001:2017 Requirements Regarding Access to the VPN with Single-Factor Authentication.**** As is already known, attackers, after gaining access to the internal network, had to perform lateral movement to learn the credentials of a user with administrative privileges that would allow them access to other subnets in order to launch the attack. As indicated in the statements of the Responsible Party, system administrators' access to the subnet (different from that of ordinary users) occurred, at the time of the incident, through the use of particularly strong and complex passwords (20 characters containing uppercase letters, lowercase letters, and special characters, to be renewed every 30 days, and the current password must not coincide with the last four used). Furthermore, the network configuration prior to the attack required direct access for all users to the authentication server in the domain. If the networks had not been adequately configured and segregated in terms of access and filtering, the consequences of the attack would have had a significant impact on the rights and freedoms of the data subjects. It is important to emphasize that the minimum security measures provided by AgID foresee three different levels (Minimum, Standard, High) and, regarding the "Appropriate Use of Administrator Privileges," classify two-factor authentication for AdS access as a "High" level measure (it is noted that the mandatory measures are those classified as "Minimum," see AgID Circular No. 2/2017 ABSC 5 - CSC 5). Among other things, passwords of at least 14 characters are considered "High" level; therefore, the 20-character password required for access to systems by Administrators can be considered absolutely and indisputably robust.

****Specific Reference to the Duty to Protect Personal Data from Unauthorized and Accidental Modifications and Access, Both During Transfer and Storage:**** "The Data Controller had evidence of adequate guarantees from the Responsible Party, particularly concerning the possession of certifications for the security management system based on international standards (in particular ISO 27001:2017, which is based on in-depth security controls regarding the availability, confidentiality, and integrity of the data). Specifically, all access to the systems occurred via encrypted protocols (HTTPS/TLS) that ensure the encryption of data in transit."

****Specific Reference to the Duty to Log Relevant Events for Information Security and Monitor Them to Timely Detect Possible Security Incidents:**** "The Responsible Party at the time of the incident was equipped with adequate measures to promptly detect personal data breaches; specifically, the systems related to the Microsoft Windows Defender ATP console and Microsoft SIEM correctly sent alerts regarding possible malicious activities."

****Specific Reference to the Duty to Ensure the Restoration of IT Systems in Case of Disaster and Operational Continuity, Ensuring the Availability of Personal Data Following Significant Security Incidents:**** "The security measures adopted both in the pre-incident and post-incident phases allowed for the restoration of applications through offline backup copies. In this regard, it is specified that the operational continuity of the applications was guaranteed, particularly the tools supporting the vaccination campaign and the booking of healthcare services, as already stated in the documentation in possession of this Authority. This restoration was made possible due to the configuration of the systems and the design of the data center, which therefore, solely for this reason, comply with the principles established by Article 25 of the Regulation. It is deemed necessary to emphasize that the temporary unavailability of personal data (limited to the time strictly necessary for the restoration of the applications) did not cause any detriment to the rights and freedoms of the data subjects and was determined by the implementation by the Responsible Party of the necessary procedures to address the attack in order to avoid worse consequences. It should not be underestimated that the aforementioned timely restoration was achieved precisely because, thanks to the configuration of the systems' architecture and the design of the Data Center (in compliance with the principles of Article 25 of the GDPR), which provided for a division into logically and/or physically separate networks and rooms, personal data remained protected."

****Specific Reference to the Duty to Have Adequate Procedures for Managing Personal Data Breaches, Including Procedures for Their Documentation:**** "The prompt activation by the Regional Council and the Company and the containment of the potential scope of the incident, as well as the restoration of temporarily suspended services (exclusively for the necessary technical checks), are all elements that demonstrate per se the compliance of the systems with the mentioned requirement."

****Regarding the Elements for Evaluations Pursuant to Article 83, Paragraph 2, of the Regulation:****

"The incident did not result in data exfiltration and did not cause any damage to the rights and freedoms of the data subjects. As repeatedly noted, the incident did not result in any loss of confidentiality and integrity of the data. Regarding availability, it is noted that it was limited to the time necessary for the Entity to assess the incident and to implement the necessary mitigation and remediation actions."

Therefore, in light of the above, the framework undoubtedly refers to a minor violation. The duration of the violation is also to be considered extremely limited compared to the potential impact that would have arisen in the absence of the adoption of all the risk containment operations extensively described. The temporary unavailability of regional services should not be framed within the context of a violation of the rights and freedoms of the data subjects, but rather within the context of a necessary and immediate action to mitigate possible risks, specifically to protect the rights and freedoms of the data subjects themselves. To support this assertion, it is reiterated that the post-incident interventions did not result in suspensions of emergency services (Ares 118, Civil Protection, NUE 112) and did not hinder the vaccination campaign in any way, as the temporary unavailability of the vaccination platform did not cause any delays in the booking system, which, at the time of its reactivation, allowed for the use of booking slots that were already available during the pre-incident phase;

"the fact that the hacker attack originated externally to the Administration, the nature of the malware repeatedly highlighted, and the modes of attack support the thesis that the psychological elements in question do not pertain in any way to either the Data Controller or the Data Processor. Therefore, the adopted conduct does not reveal elements of intent or negligence";

"despite [...] the virus being unknown to the best and most updated detection systems of the time, the measures adopted proved to be adequate and effective in preventing the further spread of the malware. Therefore, the described facts effectively support the thesis of the adequacy of the technical and organizational security measures implemented pursuant to Articles 25 and 32 of the Regulation, including the post-incident mitigation measures";

"there have been no previous cyber attacks against the systems of the Lazio Region, therefore there are no relevant previous violations attributable to the case at hand";

"the Data Controller has always adopted a collaborative and proactive attitude towards this Authority, based on the principles of correctness, loyalty, and transparency. The first and subsequent notifications sent periodically to this Authority serve as evidence in this regard";

"the Data Controller has made a timely report of the violation. In response to the violation that occurred between July 31 and August 1, 2021, the Data Controller, in fact, on the evening of August 1, informed this Authority about the incident via PEC, through its then DPO, and on XX date, made the preliminary online notification of the personal data breach through the Garante portal, without unjustified delay and within the 72 hours prescribed by Article 33 of the Regulation";

"there have never been notifications of violations related to matters of the same subject, therefore, no measures pursuant to Article 58, paragraph 2 have been ordered by this Authority either against the Data Controller or against the Data Processor";

"in the absence of an approved and applicable code of conduct to the case at hand, the Data Processor, at the instigation of the Data Controller, obtained on December 11, 2020 (a date prior to the violation in question), certification of security standards for the protection of information UNI CEI EN ISO/IEC 27001:2017. This certification was confirmed following maintenance visits (post-incident) [...]. In the period following the incident, the Data Processor also obtained the following additional

certifications: ISO 27017 on July 20, 2022 (reference standard for general security controls for users and cloud service providers); ISO 27018 on July 20, 2022 (standard for controls for public cloud service providers acting as data processors)".

2. Outcome of the investigative activity.

With reference to the applicable regulations, it is observed that:

pursuant to the Regulation, "health data" is considered to be personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveals information related to their health status (Article 4, paragraph 1, no. 15, of the Regulation). Recital no. 35 of the Regulation further specifies that health data "includes information about the natural person collected during their registration to receive health care services"; "a number, symbol, or specific element assigned to a natural person to identify them uniquely for health purposes"; the Regulation provides that personal data must be "processed in a manner that ensures adequate security [...] including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage ('integrity and confidentiality')" (Article 5, paragraph 1, letter f), of the Regulation);

by virtue of the aforementioned principle of "integrity and confidentiality" (Article 5, paragraph 1, letter f), of the Regulation), the Data Controller must (see the "Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default", adopted by the European Data Protection Board – hereinafter "Board" – on October 20, 2020, specifically point 85):

assess the risks to the security of personal data, considering the impact on the rights and the

****freedom of the data subjects, and effectively counter those identified;****

1. ****take into account security requirements in the design and development of the system as soon as possible, integrating and continuously conducting relevant tests;****

2. ****define data processing in such a way that a minimum number of people need to access personal data to perform their functions, and limit access accordingly;****

3. ****protect personal data from unauthorized and accidental changes and access, both during their transfer and during their storage;****

4. ****record relevant events for information security purposes and monitor them to promptly detect any security incidents;****

5. ****ensure the restoration of computer systems in the event of a disaster and operational continuity, ensuring the availability of personal data following relevant security incidents;****

6. ****have adequate procedures for managing personal data breaches, including procedures for their documentation;****

7. ****Article 32 of the Regulation, concerning the security of processing, establishes that "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of the processing, as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...]" (par. 1) and that "in assessing the appropriate level of security, particular consideration is given to the risks presented by the processing that arise in particular from the destruction, loss, alteration, unauthorized disclosure, or accidental or unlawful access to personal data transmitted, stored, or otherwise processed" (par. 2);****

8. ****the "Guidelines 9/2022 on the notification of personal data breaches under the GDPR" (hereinafter "Notification Guidelines"), adopted by the Committee on March 28, 2023, highlight that "a security incident that results in the unavailability of personal data for a certain period of time constitutes a breach, as the lack of access to data can have a significant impact on the rights and freedoms of natural persons" (sec. I.B.2);****

9. ****Article 25, par. 1, of the Regulation provides that "taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons posed by the processing, both at the time of determining the means of processing and at the time of the processing itself, the data controller [must implement] appropriate technical and organizational**

measures, such as pseudonymization, aimed at effectively implementing the principles of data protection, such as minimization, and integrating the necessary safeguards into the processing to meet the requirements of this Regulation and protect the rights of data subjects” (see also recitals 75 and 78 of the Regulation);**

10. **based on the aforementioned principle of “data protection by design,” controllers should conduct periodic reviews of the security measures in place to safeguard and protect personal data, as well as the procedure for managing data breaches. The obligation to maintain, verify, and update, where necessary, the processing also applies to pre-existing systems. This implies that systems designed before the Regulation came into force must undergo checks and maintenance to ensure the application of measures and safeguards that effectively implement the principles and rights of data subjects. This obligation also extends to processing carried out by a processor. In fact, the processing operations carried out by a processor should be regularly reviewed and assessed by the controller to ensure that they continue to comply with the principles and allow the controller to fulfill the obligations set out in the Regulation (see the cited “Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default,” especially points 7, 38, 39, and 84).**

Acknowledging what has been represented by the Region in the documentation on file and in the defense briefs, it is noted that:

1. **in general, the ownership of personal data processing entails a responsibility on the part of the entity holding that role and, therefore, in this case, the Region regarding the choices made concerning the purposes and means of such processing. In fact, as also indicated in the Guidelines 07/2020 on the concepts of data controller and data processor under the GDPR (adopted on July 7, 2021, by the Committee), even if the service provided by the processor is defined specifically in advance by the latter, it is still the responsibility of the controller to make the final decision approving the methods of executing the processing and to request any modifications (see point 30);**

2. **furthermore, with specific reference to the measures adopted by the processor, based on the instructions given by the controller, in order to ensure compliance with the security obligations set out in Article 32 of the Regulation, it remains the case that the controller remains responsible for implementing appropriate technical and organizational measures to ensure, and be able to demonstrate, that the**

processing is carried out in accordance with the Regulation, as required by Article 24 of the same (see points 37 and 135). Furthermore, in addition to the mandatory supervisory obligations, the responsibilities of the data controller do not cease with the conclusion of the legal act referred to in Article 28, paragraph 3, of the Regulation and with the provision of instructions related to processing, but continue for as long as the processor processes the data on their behalf. Therefore, both the controller and the processor may be subject to sanctions in the event of non-compliance with the obligations established by the Regulation, as both are directly required to ensure compliance (see point 9 of the aforementioned Guidelines); in such cases, any corrective actions are calibrated with different degrees of severity based on actual responsibilities and the degree of decision-making autonomy in the specific case; generally speaking, with reference to the recurring arguments based on LAZIOcrea's possession of the information security management system (ISMS) certification in accordance with the UNI CEI EN ISO/IEC 27001:2017 standard, extended to the controls of ISO 27017 and ISO 27018, it is noted that such certification is not currently among those provided for by Article 42 of the Regulation. In any case, certification under Article 42 of the Regulation, while it may be used by controllers or processors as an element to demonstrate compliance with the obligations of the Regulation, does not automatically imply compliance. Furthermore, it should be considered that the certification of an ISMS may be limited to specific areas (services and/or locations) of the organization (summarized in the certificate issued by the certification body) and that the certification process of an ISMS, primarily based on the results of audits (documentary and field checks), contains elements of uncertainty both because it is linked to the concept of risk and because it is conducted on a sample of the processes that the organization, while maintaining good faith, submits for certification. Therefore, certification of an ISMS based on ISO/IEC 27001 does not guarantee, in itself, levels of security, controls, or security measures established or set a priori, but ensures the adoption of the controls that

the organization has identified and deemed appropriate based on its own risk assessment. The data controller, therefore, when using a certified data processor, according to certification mechanisms, regardless of whether they are approved or not under Article 42 of the Regulation, should always verify whether the guarantees offered by the processor are effective and adequate for the processing entrusted to them; with reference to the violation of the principle set out in Article 5, paragraph 1, letter f), and the obligations set out in Article 32 of the Regulation: the processing carried out in the context in question requires the adoption of the highest security standards in order not to compromise the confidentiality, integrity, and availability of personal data, including health data, of millions of data subjects assisted. This also takes into account the purposes of the processing and the nature of the personal data processed, which also belong to special categories. On this basis, the security obligations imposed by the Regulation require the adoption of stringent technical and organizational measures, including, in addition to those expressly identified in Article 32, paragraph 1, letters a) to d), all those necessary to mitigate the risks presented by the processing. In this regard, it is noted that, with reference to the critical issues related to the processing carried out by the Company on behalf of the Region, it is the responsibility of the data controller to "implement adequate and effective measures [and to ...] demonstrate compliance of the processing activities with the [...] Regulation, including the effectiveness of the measures" adopted (recital 74 of the Regulation), even if they rely on a processor for the performance of certain processing activities, to which they must give specific instructions, including from a security perspective (recital 81 and Article 32, paragraphs 1, letter d), and 4, of the Regulation). In fact, the controller remains responsible for implementing adequate technical and organizational measures to ensure and be able to demonstrate that the processing is carried out in compliance with the Regulation (Articles 5, paragraph 2, and 24 of the Regulation; see the aforementioned Guidelines 07/2020 on the concepts of data controller and data processor under the GDPR, specifically point 41); regarding the failure to adopt adequate measures to promptly detect personal data breaches: - on July 31, 2021, from 16:49, malicious actors carried out a series of preparatory operations for the cyber attack, following which, at 21:12, "Microsoft security platforms generated a security incident of High severity called Multi-stage incident involving Execution & Command and control on multiple endpoints reported by multiple sources, consisting of a total of 2189 alerts. The incident reported the detection of malicious activity on multiple systems." From 00:00 on August 1, 2021, "the routine of encrypting the systems was initiated"; - the Company had "evidence in the early hours of the morning of August 1 when some virtual machines became unusable"; in this regard, it stated that "following the detection of 'hostile activity' (2,189 alerts) by the 'Microsoft Windows Defender ATP console' on the evening of July 31, 2021, [...] this monitoring tool was not monitored 24/7" and, therefore, "it was not possible to manage such alerts with 'greater'". "timeliness". This is also due to the fact that at the time the cyber attack occurred, the Company "did not have dedicated personnel (internal or external) for the 24/7 analysis of alerts generated by Microsoft's SIEM, pending the activation of a security operations center (SOC) service provided by Leonardo S.p.a., which took place in the first days of August 2021";

- it is therefore established that the inadequate management of the aforementioned alerts did not allow the Company, and thus the Region, to become promptly aware of the personal data breach that occurred; in this regard, it is irrelevant, in fact, what the Region argued in its defensive memoranda regarding the circumstance that "for public administrations, the current legislation still does not provide for the obligation to activate a continuously monitored SOC 24/7", as, from the perspective of data protection, the Regulation, in compliance with the principle of accountability, assigns to the data controller and the processor the task of identifying and adopting technical and organizational measures suitable to ensure a level of security appropriate to the risks presented by the processing, which in this case were high due to the nature of the data processed, the large scale of the affected individuals, including vulnerable ones, involved, as well as, in the event of a breach, the possible negative consequences for the affected individuals, particularly regarding the exercise of the right to access healthcare;

with regard to the failure to adopt adequate measures to ensure the security of networks:

- the Company had not adopted adequate measures to segment and segregate the networks on which the workstations of its employees, those of the employees of the Lazio Region, as well as the systems (servers) used for processing carried out as a controller or processor on behalf of the Region were located. In particular, the filtering rules configured on the firewall systems present in the data center managed by the Company, limited only to specific critical systems or services, did not prevent the propagation of malware on approximately 180 systems;

- within the analysis activities conducted by Leonardo S.p.a. regarding the personal data breach in question, a "Mitigation, Eradication & Improvement Plan" (hereinafter "Plan") was defined, which includes the adoption, among others, of specific actions aimed at segregating and securing the various systems managed by the Company. In particular, these actions include "network segmentation avoiding excessively wide subnets and effectively limiting the possibility for a potential attacker to execute lateral movements", the "complete reinstallation of all server systems and simultaneous placement in network segments divided by security layers (Tier), with limited access and manageable only from a limited number of workstations, which are in turn isolated from other networks (PAW, Privileged Access Workstation)", as well as the "redesign of the network [...] favoring the principle of least privilege";

- moreover, at the time the personal data breach occurred, remote access via VPN to the Region's network was carried out through a computer authentication procedure based solely on the use of a username and password. In relation to this aspect, the Region and the Company, following the incident, deemed it necessary to activate a two-factor authentication procedure, as also provided for in the aforementioned Plan;

- what was stated by the Region in its defensive memoranda does not allow for overcoming the critical issues identified in the initiation of the proceedings, as, even if "the logical separation and physical segregation of networks [...] prevented hackers from exfiltrating the data present in the Data Center", this did not prevent unauthorized individuals from accessing and compromising, rendering unavailable, many server systems that, as stated by the Company during the inspection assessment, at the time of the breach, could be reached from the network used for the VPN access of the employees of the Lazio Region;

with regard to the obsolescence of the base software installed on some processing systems:

- from the documentation on file, it emerged that the server with hostname "RLWSIRIFT01" was "one of the main junction points used by the attacker in the final phase of the attack" that led to the personal data breach in question. The Company highlighted that on the "server with hostname 'RLWSIRIFT01' [...] outdated base software was installed for which no updates or security patches from the manufacturer were available. This circumstance was due to the need to ensure the operation of a legacy web application that required a specific version of the operating system and application server. Exploiting known vulnerabilities of the base software present on the aforementioned server, malicious actors were able to obtain authentication credentials with administrative privileges [...] used in the subsequent phases of the cyber attack." In particular, it emerged that an obsolete operating system (Windows Server 2008 R2 Standard) was installed on the processing system in question, for which the manufacturer (Microsoft) had ceased distribution of security updates. This made patching of that system particularly difficult, realistically requiring the adoption of ad hoc measures that were not timely enough to address new vulnerabilities;

- only following the personal data breach did the Company "identify the (few) servers that, to ensure the operation of some legacy services, still using obsolete operating systems and has taken appropriate measures for segregation, at the network level, as well as for monitoring security events";

- what is reported by the Region in the defense briefs does not allow for overcoming the Office's observations regarding the use of obsolete base software, for which security updates are no longer available, also considering that the server systems on which such software was installed, contrary to what was asserted, were not adequately isolated from other server systems through which data

processing, including health-related data of the beneficiaries of the regional health service, was carried out;

regarding the failure to adopt adequate measures to ensure the availability and resilience of the processing systems and services:

- the Company, at the time of the security incident, was using a backup management system and that “specific backup management procedures had not been defined, but it was expected that each project manager would communicate, at the time of operational release, using a specific model, among other things, information on the type and retention of backups to be performed. The frequency of backups was daily”;
- backup management was carried out using a “table containing the list of projects for which backups were performed, indicating the project managers, the name of the schema, the hosts, and the related retention policies”;
- only following the personal data breach did the Company adopt a new backup management system that allows for easier management and monitoring of data and system backups based on what is indicated by each project manager at the time of operational release;
- what the Region stated in the defense briefs does not allow for overcoming the Office's observations regarding the methods adopted to ensure the availability and resilience of the processing systems and services, including backup management, as they were found not to be in line with best industry practices and not adequate to the context of the processing carried out by the Company on behalf of the Lazio Region;
- the breach resulted in the inability to use many information systems of the Region, some of which process health data, including: ASUR – Regional Unified Health Registry; new RECUP – Management of appointments, admissions, cancellations; ESCAPE, for the management of reports related to laboratory tests; payments for services related to outpatient specialist activities including online payments via PAGOPA; Regional system for sending flows for informational debt related to specialist services under the SSN, intramoenia services, home services, and services provided at clinics, hospital admissions, emergency room accesses; RICDIG – System for recording dematerialized prescriptions for drug prescriptions and outpatient services; neonatal and oncological screening activities; Regional Covid-19 surveillance platform; ADVICE – Teleconsultation system for consultations to second-level DEAs; AVR System – Regional Vaccination Registry;
- the aforementioned information systems, through which health data of the beneficiaries of the regional health service are processed, were unavailable for a period extending, in some cases, for several months; the company LAZIOcrea has indeed proceeded to restore them, in a cloud environment, gradually prioritizing the most critical ones (e.g., Covid-19 vaccination) to complete the full restoration in October 2021 (cf. notifications from the company LAZIOcrea of September 10 and October 29, 2021 – which the Region expressly refers to with the notification of XX – as well as reservations from the minutes of the inspection findings of XX);
- the lack of availability of access to the data stored on the aforementioned systems was determined: i) directly by the cyber attack which, compromising the application layer of the virtualization system, rendered approximately 180 virtual server systems unavailable and the data processed therein inaccessible; ii) indirectly by LAZIOcrea's decision to shut down all server systems as, at the time of the cyber attack, it was unable to determine which were compromised or to prevent further propagation of the malware due to the lack of segregation of the networks on which they were hosted;
- therefore, had LAZIOcrea adequately segregated the networks on which the server systems and the workstations of its employees and the Lazio Region were located, the Company would not have had to proceed with shutting down the aforementioned server systems, and thus the healthcare facilities would not have suffered the unavailability of access to numerous information systems and their related data;

- network segregation is, moreover, one of the most common measures adopted within data centers that host IT systems dedicated to processing different categories of personal data, including health-related data, which LAZIOcrea – as a company operating in the ICT sector under the in-house providing model – should certainly have ensured, considering the context and characteristics of the processing for which it was designated as responsible by the Region and the healthcare facilities;

with reference to the violation of the principle set out in Article 25, paragraph 1, of the Regulation: Article 25 of the Regulation requires that the measures and guarantees identified and adopted by the data controller be

specifically related to the implementation of data protection principles in the context of the specific processing carried out; the measures and guarantees must be designed to be robust, and the data controller must be able to implement further measures to address any potential increase in risks. The effectiveness of the measures depends on the context of the processing and other elements that the controller must consider when determining the means of processing; regarding the arguments based on LAZIOcrea's possession of the certification of the (SGSI) in accordance with the UNI CEI EN ISO/IEC 27001:2017 standard, reference is made to the above observations regarding the duties of the data controller in adopting effective and adequate measures for processing, even when entrusted to a data processor; moreover, even in the case where "a processing is certified pursuant to Article 42, the controller is still required to ensure constant monitoring and improvement of compliance with the criteria of the DPbDD" (see "Guidelines 4/2019 on Article 25 - Data Protection by Design and by Default," point 91); the risk assessment carried out by the processor can be used, but is not in itself sufficient to allow the data controller to adequately design the processing in order to integrate guarantees to protect the rights and freedoms of the data subjects and to adopt additional measures - including organizational ones - beyond those identified by the data processor; what has been reported by the Region in the defense briefs does not allow for overcoming the observations of the Office regarding the violation of the principle of data protection by design, particularly with reference to the adequacy and effectiveness of the measures adopted in relation to the context and scope of the processing carried out by the controller.

3. Conclusions.

In light of the evaluations mentioned above, taking into account the statements made by the Lazio Region during the investigation and considering that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or exercise of the powers of the Guarantor," the elements provided in the defense briefs do not allow for overcoming the observations notified by the Office with the initiation of the procedure, nor do any of the cases provided for in Article 11 of the Guarantor Regulation No. 1/2019 apply. For these reasons, the illegality of the processing of personal data carried out by the Lazio Region is noted, as stated in the reasoning, in violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation. In this context, considering that measures have been adopted to overcome the critical issues described above, the conditions for the adoption of corrective measures pursuant to Article 58, paragraph 2, of the Regulation do not exist.

4. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation, caused by the conduct of the Lazio Region, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 3, 4, and 5, of the Regulation. It should be noted that the Guarantor, pursuant to Articles 58, paragraph 2, letter i), and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures referred to in this paragraph, or in place of such measures, depending on the circumstances of each individual case" and, in this context, "the College [of the Guarantor]

adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Guarantor Regulation No. 1/2019). The aforementioned administrative pecuniary sanction, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 85, paragraph 2, of the Regulation. With specific regard to the nature and severity of the violations (Article 83, paragraph 2, letters a), d), and g), of the Regulation), it must be considered that the number and sensitivity of the services affected and, as a result, the high number of data subjects involved and the types of personal data subject to violation (including special categories referred to in Article 9 of the Regulation, or other data characterized by particular sensitivity such as salary data and banking data), and this regardless of the lack of exfiltration of the same data. In light of these circumstances, it is believed that, in this specific case, the level of severity of the violations committed by the data controller is high (Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted by the Committee on May 23, 2023, point 60). Additionally, pursuant to Article 83, paragraph 2, letter e), of the Regulation, the Region has already been recipient of certain corrective and sanctioning measures.

Furthermore, pursuant to Article 83, paragraph 2, letter h) of the Regulation, the Authority has taken note of the event from the timely notification of the violation sent by the Region.

In a favorable sense for the holder, it should be considered, pursuant to Article 83, paragraph 2, letters c) and f) of the Regulation, that the Region cooperated with the Authority by introducing, in the context of the Covid-19 emergency, measures suitable to overcome the highlighted critical issues.

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the monetary sanction provided for by Article 83, paragraphs 3, 4, and 5 of the Regulation, in the amount of €120,000.00 (one hundred twenty thousand) for the violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation or, as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the Authority's website of this provision, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Authority's Regulation No. 1/2019, should be applied, also taking into account the number of interested parties involved, the type of personal data subject to violation, and the extent and impact on the availability of the affected services.

Lastly, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE, THE AUTHORITY

declares the illegality of the processing of personal data carried out by the Lazio Region for the violation of Articles 5, paragraph 1, letter f), 25, paragraph 1, and 32 of the Regulation as stated in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i), and 83 of the Regulation, as well as Article 166 of the Code, the Lazio Region, tax code 80143490581, represented by the legal representative pro tempore, to pay the sum of €120,000.00 (one hundred twenty thousand) as an administrative monetary sanction for the violations indicated in this provision; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanction.

ORDERS

the Lazio Region, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €120,000.00 (one hundred twenty thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent executive acts in accordance with Article 27 of Law No. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Authority's website and the annotation of this provision in the Authority's internal register, as provided for by Article 57, paragraph 1, letter u), of the Regulation, of the violations and the measures adopted in accordance with Article 58, paragraph 2, of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, it is possible to appeal against this provision before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, March 21, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE SECRETARY GENERAL

Mattei